

UyJoy V2 — Stage 7 verification report

Run before deploying the V2 launch to production traffic. Generated 2026-05-16.

Summary

#	Stage 7 step	What was done	Result
7.1	Build + bundle audit	Static checks; live build runs locally	PASS (static)
7.2	Lighthouse / Core Web Vitals	Cannot run from sandbox; instructions below	ACTION REQUIRED
7.3	End-to-end smoke test	Cannot click from sandbox; checklist below	ACTION REQUIRED
7.4	Security verification (static)	15 source-level checks	15 / 15 PASS
7.5	Backups & rollback runbook	docs/runbook.md extended	PASS

7.4 — Static security verification (PASS 15/15)

Every check below was run against the current source tree.

CHECK 1 — Customer-PII fields are not in publicUnitSelect / publicProjectSelect.

Result: zero hits

CHECK 2 — Customer-PII fields not used in any public-facing route (only the admin API and the secure copy-to-all path reference them, both auth-gated).

Result: PASS

CHECK 3 — Middleware still requires NextAuth JWT for /portal/management-x7k9 (except /login) and for mutating /api/* content routes.

Result: PASS

CHECK 4 — protectedApiPrefixes includes /api/ai, /api/upload, /api/users; contentApiPrefixes covers projects, buildings, floors, units, faqs, hero-images.

Result: PASS

CHECK 5 — All 6 security headers present in next.config.mjs: Strict-Transport-Security, Content-Security-Policy, X-Frame-Options, X-Content-Type-Options, Referrer-Policy, Permissions-Policy.

Result: PASS

CHECK 6 — POST /api/leads: in-process rate limit (5/min), strict Uzbek phone regex /\+998\d{9}\$/, honeypot fields, Turnstile verification when env keys set, dev-mode bypass logs warning.

Result: PASS

CHECK 7 — AI image routes use src/lib/secure-image-input.ts. Local files resolved with path.resolve and checked against PUBLIC_UPLOADS_DIR — path traversal blocked. External URLs limited to res.cloudinary.com HTTPS.

Result: PASS

CHECK 8 — Upload route uses sharp.metadata() to verify the buffer is a real image (blocks spoofed MIME), rate-limited 20/5min, Cloudinary 'strip_profile' applied.

Result: PASS

CHECK 9 — CSV export in LeadsClient uses escapeCsvValue() which quotes values, doubles inner quotes, and prefixes leading =/+/-/@/tab/CR with a single quote (formula injection block).

Result: PASS

CHECK 10 — requireAdmin() called as the first line of every admin server page (8 server pages confirmed).

Result: PASS

CHECK 11 — revalidateTag / invalidateProject called on every content mutation route (projects, buildings, floors, copy-to-all, units, hero-images, faqs).

Result: PASS

CHECK 12 — src/lib/project-copy.ts is a harmless export-stub (deletable).

Result: PASS

CHECK 13 — No leftover hardcoded @wxusan, +998 77 041, or navruz-residence-master.png references in src/.

Result: PASS

CHECK 14 — Privacy + Terms linked from every lead surface: ContactForm, ApartmentLeadModal (×2), FloatingContact, Footer.

Result: PASS

CHECK 15 — Prisma migration registers all 7 indexes (Building.projectId, Floor.buildingId, Unit.floorId, Unit.status, Lead.projectId, Lead.unitId, Lead.status+createdAt) and all 6 Lead snapshot fields.

Result: PASS

7.1 — Build & bundle audit (static)

Real npm run build cannot run from the sandbox (permission constraints on .next and node_modules/.prisma created by the host). The user already confirmed build passed locally. The static checks below are what can be verified without running build:

Static confirmations

- puppeteer is correctly under devDependencies in package.json (not dependencies). No imports in src/.
- MapLibre is dynamically imported in src/app/page.tsx via next/dynamic — stays out of the main route bundle.
- Cloudinary helpers (getHeroImageUrl, getCardImageUrl, getFullImageUrl, getThumbnailUrl) exist in src/lib/cloudinary.ts.
- Sentry configs (sentry.client.config.ts, sentry.server.config.ts, sentry.edge.config.ts) and instrumentation.ts registered.

Run on your machine (any time before deploy):

```
rm -rf .next npx tsc --noEmit npm run build
```

If the build output reports a chunk > 300 KB for any single route, open it in @next/bundle-analyzer:

```
ANALYZE=true npm run build # if you've added @next/bundle-analyzer # otherwise inspect  
.next/static/chunks/app/<route>/page.js by hand
```

7.2 — Lighthouse / Core Web Vitals

Cannot run from the sandbox (no headless Chrome). Run this from your terminal:

```
npm run build npm run start # serves on http://localhost:3000 # then open Chrome incognito  
on localhost:3000 # DevTools -> Lighthouse -> Mobile, slow 4G, 4x CPU # run on / and  
/kvartiralar
```

Targets

- Performance ≥ 85 mobile, ≥ 95 desktop.
- LCP < 2.5 s.
- CLS < 0.1.
- Total blocking time < 200 ms.

If LCP > 2.5 s, the usual offenders are:

- A hero image not going through getHeroImageUrl() — check ProjectTopView and the kvartiralar hero.
- Fonts not being preloaded (next/font handles this — verify the layout.tsx still imports them).
- MapLibre re-imported statically somewhere — it must only enter the bundle via the next/dynamic call in page.tsx.

7.3 — End-to-end smoke test

Run this against your staging deploy (or local production build). ~5 minutes. All flows must complete without 5xx and without browser console errors.

Homepage contact form

- Open / in incognito.
- Fill the form at the bottom of the page. Submit.
- Confirm a green 'thank you' state.
- Confirm the lead appears in /portal/management-x7k9/leads within 5 seconds.
- Confirm Sentry stays quiet (no error events for this submit).

Apartment modal lead

- Click the explore section. Drill into a building, floor, available unit.
- Submit the form. Complete the Turnstile widget.
- Confirm the lead lands in admin with the correct unit number, building, source='interactive-floor' (or whichever source applies).

Waitlist on sold unit

- Open a SOLD or RESERVED unit modal.
- Verify the form renders with 'notify me' copy (NOT a static unavailable paragraph).
- Submit. Confirm the lead appears with source='waitlist'.

Cache invalidation

- In admin, mark an available unit as 'reserved' with customer name + phone.
- Within 5 seconds, hard-refresh the public homepage.
- Confirm the unit shows reserved (amber polygon, no 'available' badge).

CSV injection check

- Create a test lead through the public form with name '=cmd|/c calc!A1'.
- In admin, export leads CSV.
- Open the CSV in Excel.
- Confirm the cell shows the LITERAL text (no formula executes, no security warning).
- Delete the test lead.

Security headers on production

- `curl -sI https://`
- Confirm 6 headers present: Strict-Transport-Security, Content-Security-Policy, X-Frame-Options, X-Content-Type-Options, Referrer-Policy, Permissions-Policy.

PII not in HTML

- `curl -s https:// | grep -E 'customerPhone|customerName|customerNotes'`
- Must return zero matches.
- Same for /kvartiralar.

Auth wall

- `curl -i https:///api/leads` — expect HTTP 401.
- `curl -i -X POST https:///api/upload` — expect HTTP 401.

Rate limit

- Loop `POST /api/leads` 8x from one IP without Turnstile.
- Expect the 6th request onward to return 429.

7.5 — Backups & rollback

Runbook extended at docs/runbook.md with:

- Full smoke-test procedure (matches 7.3 above).
- Production security-verification curl snippets.
- Lighthouse targets + usual offenders.
- Vercel rollback procedure (already present).
- Neon PITR procedure (already present).

One-time actions you still need to do at the host (cannot do from this audit session):

- Neon: enable Point-in-Time Recovery; confirm WAL retention ≥ 7 days.
- Neon: take a manual snapshot labeled 'pre-v2-launch' immediately before flipping production traffic.
- Vercel: set NEXT_PUBLIC_SENTRY_DSN, SENTRY_AUTH_TOKEN, SENTRY_ORG, SENTRY_PROJECT, NEXT_PUBLIC_TURNSTILE_SITE_KEY, TURNSTILE_SECRET_KEY in production env vars.
- Sentry: trigger one synthetic error in staging, confirm it shows up in the Sentry dashboard.
- Cloudflare Turnstile: confirm the production site key is allow-listed for your production domain.
- Cloudinary: in the dashboard, restrict upload preset to image MIME types only (defense in depth on top of the sharp check in /api/upload).

Final ship/no-ship call

Ship. All 15 static security checks pass. Stages 1–6 are confirmed complete. The runbook is in place. The remaining items (Lighthouse, smoke test, snapshot, env vars) are operations you must run yourself at deploy time — they are documented above and in docs/runbook.md. Once the env vars are populated in Vercel and the pre-v2-launch Neon snapshot exists, you can promote to production traffic.

Day-1 watch

- Sentry first-24h: keep the dashboard open. Triage any new issue within 1h.
- Vercel function metrics: watch for /api/leads or /api/upload p95 spikes — those indicate bot traffic getting through rate limits.
- PostHog: confirm event volume looks healthy. 'Joined Waitlist' should fire when sold/reserved modals get traffic.
- Neon: confirm CPU and connection counts stay flat with v1 baseline. The new indexes should keep it boring.